

# AI IDENTITY SECURITY POLICY

*AI Identity Security Capstone Project*

Organization: AI Identity Security Capstone

Prepared by: PONUGOTI RUCHITHA

Date: 22 August 2026

Version: 1.0

## Table of Contents

| Section                                    | Page No. |
|--------------------------------------------|----------|
| 1. Purpose and Scope                       | 3        |
| 2. Identity Lifecycle                      | 3        |
| 2.1 Identity Provisioning                  | 3        |
| 2.2 Authentication and Authorization       | 3        |
| 2.3 Identity Review                        | 4        |
| 2.4 Credential Rotation                    | 4        |
| 2.5 Identity Decommissioning               | 4        |
| 3. Credential Governance                   | 5        |
| 3.1 API Key Management                     | 5        |
| 3.2 Short-Lived Credentials                | 5        |
| 3.3 Secret Management                      | 6        |
| 3.4 Agent Cryptographic Identity           | 6        |
| 4. Incident Response Playbook              | 6        |
| 4.1 Leaked LLM API Key                     | 7        |
| 4.2 Compromised Agent Identity             | 8        |
| 4.3 Prompt Injection and Data Exfiltration | 9        |
| 5. Monitoring and Enforcement              | 9        |
| 6. Policy Review                           | 10       |

## 1. Purpose and Scope

---

This policy establishes identity security requirements for the AI-enabled environment assessed across Projects 1–4 of the AI Identity Security Capstone. The policy covers human users, AI agents, Auth0 applications, APIs, Machine-to-Machine identities, access tokens, API credentials, agent identities, and AI security controls.

The objective is to ensure that identities are securely provisioned, authenticated, authorized, monitored, reviewed, rotated, and decommissioned, while reducing the risk identified during the threat-modeling and red-team activities.

This policy applies to:

- Human users accessing protected applications and APIs.
- AI agents performing automated actions.
- Regular Web Applications and Machine-to-Machine applications configured in Auth0.
- APIs and custom permissions including read:ai-data and write:admin.
- JWT access tokens and associated identity claims.
- Agent-to-agent authentication and cryptographic identity controls.
- LLM inputs, outputs, prompts, tools, and guardrail controls.
- Secrets, API keys, client credentials, and other authentication material.

The security approach follows least privilege, short-lived credentials, continuous verification, credential protection, explicit authorization, and auditable security activity.

## 2. Identity Lifecycle

---

### 2.1 Identity Provisioning

Every human or non-human identity must have a unique identifier, an approved business purpose, an accountable owner, and documented access requirements before production access is granted.

AI agents and Machine-to-Machine applications must be registered before accessing protected APIs. Permissions must be limited to the minimum required for the approved function.

Privileged permissions, including write:admin, must not be granted by default.

### Timeline

### 2.2 Authentication and Authorization

Auth0 is used as the identity and authorization platform for the assessed application and API flows.

- Human users authenticate through the configured Auth0 Universal Login flow.
- Machine-to-Machine identities use dedicated client credentials.
- Authorization decisions must be based on validated access tokens and approved scopes.
- read:ai-data provides the approved AI-data access permission.
- write:admin provides administrative access and must be explicitly authorized.

- JWT validation must verify the algorithm, issuer (iss), audience (aud), expiration (exp), scope/permissions, and required identity claims.
- MFA must be enforced for the applicable human authentication flow.

## 2.3 Identity Review

Identity permissions must be reviewed regularly to identify excessive, unused, or unauthorized access. AI identities require additional review because automated agents can perform actions at scale.

### Review Schedule

| Review Activity            | Frequency     |
|----------------------------|---------------|
| AI agent identity review   | Every 30 days |
| Privileged access review   | Every 30 days |
| General user access review | Every 90 days |
| OAuth/M2M client review    | Every 90 days |
| Inactive identity review   | Every 30 days |

Unnecessary permissions identified during review must be removed.

## 2.4 Credential Rotation

Credentials must not remain valid indefinitely. Short-lived access tokens are preferred to reduce the impact of credential theft and replay.

| Credential Type         | Maximum Lifetime / Rotation Requirement                      |
|-------------------------|--------------------------------------------------------------|
| Access token            | 300 seconds in the hardened implementation                   |
| API key                 | Maximum 90 days; immediate rotation after suspected exposure |
| M2M credential          | Review every 90 days and rotate when required                |
| Agent cryptographic key | Rotate upon compromise or lifecycle change                   |
| Refresh token           | Rotation enabled; previous token rejected after use          |

The previous refresh token must not be accepted for reuse after a successful refresh-token exchange.

## 2.5 Identity Decommissioning

When an employee, application, AI agent, or service is no longer authorized to operate, its identity must be decommissioned.

1. Disable the identity.
2. Revoke active access and refresh tokens.

3. Remove API permissions and scopes.
4. Revoke or rotate associated credentials.
5. Disable associated API keys.
6. Archive relevant audit logs.
7. Remove unnecessary access paths.

A compromised identity must be disabled immediately rather than waiting for the normal review cycle.

### 3. Credential Governance

---

#### 3.1 API Key Management

LLM API keys and other API credentials are sensitive authentication material and must be assigned to a specific application, service, or approved owner.

- API keys must not be shared between unrelated identities or environments.
- API keys must not be hardcoded in source code or committed to public repositories.
- API keys must not be intentionally exposed in prompts, model responses, screenshots, or documentation.
- Credentials must be stored using an approved secrets-management mechanism or protected environment configuration.
- Exposed or compromised credentials must be revoked immediately.

#### API Key Rotation Requirement

All API keys must be rotated at least once every 90 days.

Emergency rotation must occur immediately when:

- A credential is exposed in a model response or source repository.
- Unauthorized activity is detected.
- An associated agent identity is compromised.
- The credential owner loses authorization.

#### 3.2 Short-Lived Credentials

Long-lived credentials must not be used by AI agents where a short-lived mechanism is available.

- Access Token TTL: 300 seconds.
- Refresh Token Rotation: Enabled.
- Old Refresh Token Reuse: Rejected.
- Expired tokens must be rejected and recorded as security events.

#### 3.3 Secret Management

Secrets include:

- LLM API keys
- OAuth client secrets

- Machine-to-Machine credentials
- Database credentials
- Agent private keys
- Service account credentials

The following standards are mandatory:

8. Store secrets separately from application code.
9. Use an approved secrets-management mechanism or protected environment configuration.
10. Restrict secret access using least privilege.
11. Rotate secrets according to the defined lifecycle.
12. Revoke compromised secrets immediately.
13. Maintain an audit trail for privileged secret access where supported.

Development, testing, and production environments must use separate credentials.

### 3.4 Agent Cryptographic Identity

AI agents communicating with other agents or services must not rely only on an attacker-controlled identity field. Protected agent communication must use cryptographic verification.

14. The sending agent signs the outgoing message using its private key.
15. The receiving service verifies the signature using the corresponding public key.
16. Messages with invalid signatures must be rejected.
17. Modified or tampered messages must not be processed.
18. Cryptographic keys must be rotated if compromise is suspected.

This control supports the Project 4 identity-verification design by binding protected messages to a verifiable agent identity.

## 4. Incident Response Playbook

The Incident Response Playbook defines the required response process for incidents involving AI identities, credentials, prompt injection, guardrail failures, and unauthorized data access.

| Phase                    | Required Action                                                                                            |
|--------------------------|------------------------------------------------------------------------------------------------------------|
| 1. Detection             | Identify the security signal and affected identity or workflow.                                            |
| 2. Containment           | Stop further unauthorized access or disclosure.                                                            |
| 3. Evidence Preservation | Preserve logs, prompts, outputs, tokens/identifiers, and timestamps without unnecessarily storing secrets. |
| 4. Notification          | Notify the security/identity owner and escalate material impact.                                           |

|                         |                                                                                   |
|-------------------------|-----------------------------------------------------------------------------------|
| 5. Recovery             | Rotate/revoke credentials, restore least-privilege access, and validate controls. |
| 6. Post-Incident Review | Document root cause, impact, corrective actions, and lessons learned.             |

## 4.1 Scenario: Leaked LLM API Key

### Detection Signals

- API key detected in an LLM/model response.
- Secret-scanning alert.
- Credential found in source code or repository.
- Unusual API usage, request volume, or cost.
- Unauthorized requests using the affected credential.
- Security monitoring or anomaly-detection alerts.

### Containment

19. Immediately revoke or disable the affected API key.
  20. Prevent further use of the credential.
  21. Review recent API activity associated with the key.
22. Identify affected applications or agents.
23. Generate a replacement credential after the exposure path is understood.

### Evidence Preservation

- Application and API logs.
- Timestamps of suspicious activity.
- Request identifiers where available.
- Location or source where the key was exposed.
- Relevant prompts or responses, stored securely and with secrets redacted.

### Notification

Notify the security team, credential/service owner, and incident response lead. Escalate to management when the exposure has significant business or customer impact.

### Recovery

24. Generate and securely deploy a replacement API key.
25. Update affected applications through the approved secrets-management process.
26. Confirm the old credential is no longer valid.
27. Monitor the new credential for suspicious activity.
28. Review root cause and implement corrective controls.

## 4.2 Scenario: Compromised Agent Identity

### Detection Signals

- Unexpected scope changes between agent requests.
- An agent requesting write:admin when its approved role only requires read:ai-data.
- Invalid or failed cryptographic signature verification.
- Unexpected API call volume.
- Reuse of expired credentials or tokens.
- Agent actions inconsistent with its assigned role.

29. **Containment** Disable the suspected agent identity.
30. Revoke active access and refresh tokens.
31. Remove privileged API scopes.
32. Disable associated API credentials.
33. Block communication from the compromised agent until verification is complete.

### Evidence Preservation

- Agent message logs.
- Signature-verification failures.
- Token and authentication events.
- Scope-change events.
- API request logs.
- Relevant timestamps and identity identifiers.

### Notification

Notify the security team, system owner, and incident response lead. Escalate if unauthorized administrative actions or protected-data access occurred.

### Recovery

34. Investigate the compromise source.
35. Generate new credentials or cryptographic key material.
36. Re-register and validate the agent identity.
37. Reapply least-privilege permissions.
38. Monitor the restored identity for abnormal behavior.

## 4.3 Scenario: Prompt Injection and Data Exfiltration

### Detection Signals

- Guardrail detecting malicious or indirect instructions.
- Attempts to override system or developer instructions.
- Requests attempting to reveal credentials, JWTs, or protected prompts.
- JWT-shaped or credential-like strings detected in model output.
- Unauthorized tool invocation attempts.
- Unexpected access to protected data or retrieval content.



- Project 3 attack behavior detected by Project 4 security controls.

## Containment

39. Block the malicious request or retrieved content.
40. Stop active tool invocation associated with the request.
41. Prevent further disclosure of sensitive information.
42. Restrict the affected agent's access to sensitive resources.
43. Rotate exposed credentials if sensitive authentication material was disclosed.

## Evidence Preservation

- Original malicious prompt or external content.
- Model response.
- Guardrail detection/blocking logs.
- Tool invocation records.
- Authentication and authorization events.
- Timestamps and affected identity information.

## Notification

Notify the AI/security team, application or agent owner, and incident response lead. Escalate when customer or sensitive organizational data was exposed.

## Recovery

44. Remove or isolate the malicious input or content path.
45. Strengthen the relevant input/output guardrail.
46. Rotate any exposed credentials.
47. Validate that sensitive data is no longer returned.
48. Re-run the Project 3 attack payload against the Project 4 hardened control.
49. Document the incident and lessons learned.

## 5. Monitoring and Enforcement

---

The environment must monitor AI identity and AI security activity for events including:

- LLM API call volume spikes.
- Unexpected scope or permission changes.
- Token reuse after expiry.
- Failed cryptographic signature verification.
- Prompt-injection attempts.
- Sensitive credential or JWT exposure in model output.
- Unexpected administrative actions.
- Guardrail blocks and repeated attack attempts.

Security alerts should include, where available:

- Timestamp
- Identity or agent identifier

- Event type
- Relevant event details
- Request/transaction identifier

Violations of this policy may result in access revocation, credential rotation, identity suspension, incident investigation, or additional security controls.

## 6. Policy Review

---

This policy must be reviewed at least every 12 months and after any significant AI identity security incident, major architecture change, or material change to authentication, authorization, or AI security controls.

Policy reviews must consider:

- New AI agents or identity types.
- Changes to Auth0 authentication or authorization architecture.
- Changes to API scopes or privileged permissions.
- Newly identified attack techniques.
- Results from Project 3 red-team exercises.
- Results from Project 4 blue-team validation.
- Changes to applicable security and governance requirements.